上讲主要内容:

- 盲签名
- 群组签名、多重签名
- 零知识证明
- 同态密码

《密码学基础》

哈爾濱工業大學(深圳)
HARBIN INSTITUTE OF TECHNOLOGY, SHENZHEN

第14讲 密钥管理

身份认证、密钥协商、Kerberos、PKI、门限密码



授课教师：徐国爱

Contents 内容



1 身份认证

2 对称密钥协商

3 非对称密钥协商

4 门限密码

什么是身份认证?

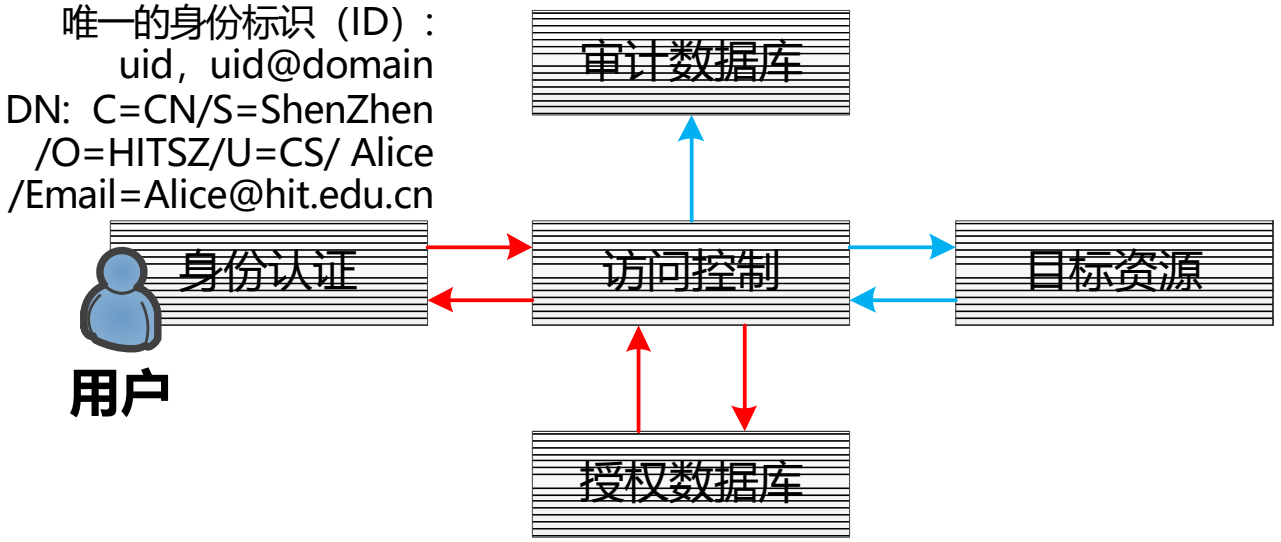
身份认证（Authentication）验证主体真实身份与其所声称身份是否相符的过程

- 你是谁? 指纹，笔迹，声音，脸型，视网膜，虹膜
- 你在哪? 物理位置验证
- 你有啥? 身份证、信用卡、钥匙、智能卡、令牌等
- 知道啥? 知识、口令、密码

入学	考试	办卡	取款	…

身份认证的作用和意义

- 身份认证就是**确保身份的真实性**，也就是说保证操作者的物理身份与数字身份(系统中所宣称的身份)相对应，**身份认证能够抵御假冒攻击**。
- 身份认证是对网络中的**实体**进行验证的过程，必须提供实体真实性的证明。在大多数情况下，**身份认证机制与权限管理和审计等应用紧密结合在一起**。
- 身份认证是许多应用系统中安全保护的**第一道设防**，它的失败可能导致整个系统失败。

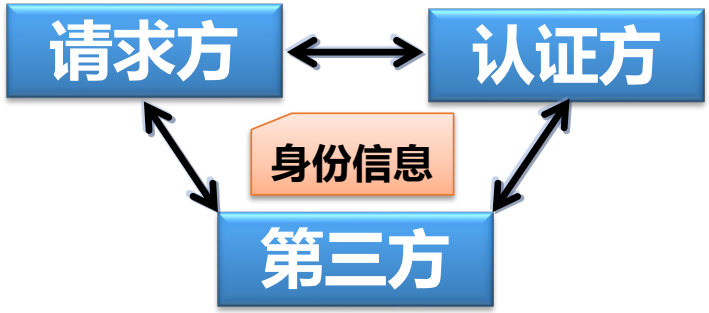


身份认证的基本模型

●身份认证的基本模型

- 请求方（Applicant）；
- 验证者（Authenticator）；
- 认证信息（Authentication Information）；
- 可信第三方(Trusted-Third Party)；





身份认证的分类

所知

根据你所知道的信息来证明你的身份
（whatyouknow，你知道什么）
密码、口令等

所有

根据你所拥有的东西来证明你的身份
（what you have，你有什么）
动态口令设备、IC卡、电子钥匙(Usb Key)等

所是

直接根据独一无二的身体特征来证明你的身份
（whoyou are，你是谁）
指纹、人脸、笔迹、声音、虹膜、DNA等

1）基于口令的身份认证



由于口令易实现、成本低、使用方便等特点，成为当前最常用的认证方式，尤其在安全性要求不是很高的应用场合

安全目标：

- 口令信息实现安全传输
- 管理员不知道用户的口令

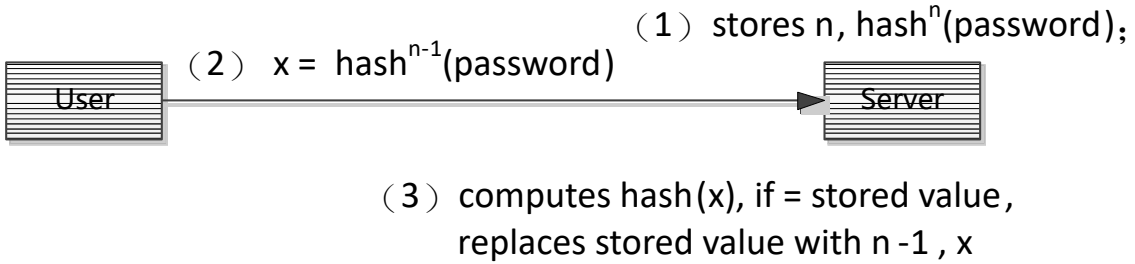
主要组成：

- 口令的初始化及更新
- 口令认证

1）一次性口令认证

方案1：口令序列

◆系统产生一个初始口令和使用次数，客户端与服务器按照特定的顺序依次计算临时口令，每个口令只用一次



$x_1=f(R)$	$x_2=f(x_1)$	…	$x_{n+1}=f(x_n)$

✓ 初始阶段：Alice输入随机数R，计算机计算$x_1=f(R)$、$x_2=f(x_1)$、…、$x_{n+1}=f(x_n)$。Alice保管x_1，x_2，x_3，…，x_n这些数的列表，计算机在登录数据库中Alice的名字后面存储x_{n+1}的值。

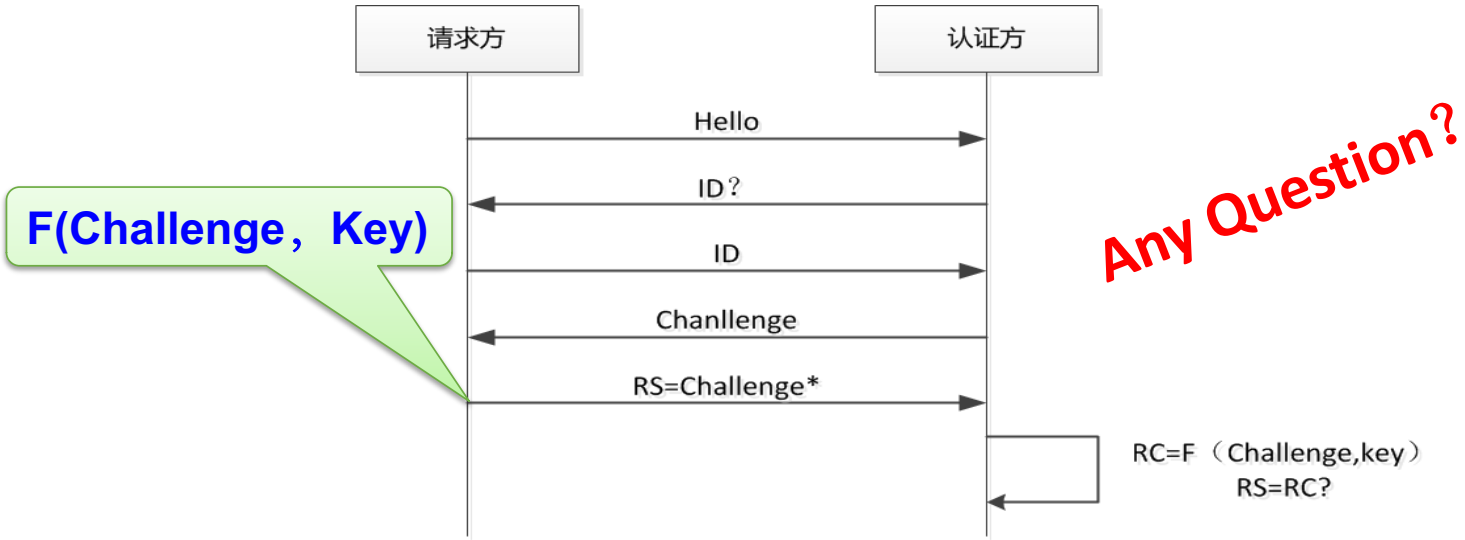
✓ 当Alice第一次登录时，输入名字和x_n，计算机计算$f(x_n)$，并把它和x_{n+1}比较，如果匹配，就证明Alice身份是真的。然后，计算机用x_n代替x_{n+1}。Alice将从自己的列表中取消x_n。

✓ Alice每次登录时，都输入她的列表中未取消的最后的数x_i，计算机计算$f(x_i)$，并和存储在它的数据库中的x_{i+1}比较。当Alice用完了列表上面的数后，需要重新初始化。

Any Question?

1）一次性口令认证

方案2：询问/应答认证



1）服务器端收到登录请求后，产生一个挑战信息发送给客户；

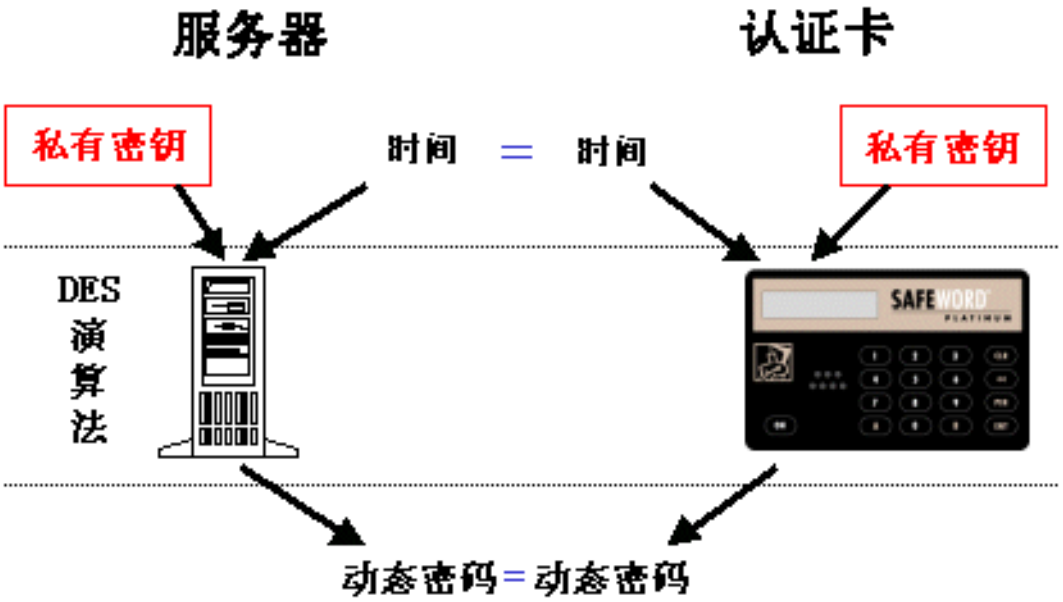
2）用户向一次性口令计算器输入私有密钥，由一次性口令计算器产生一个OTP (one time password)。此OTP通过网络发送给服务器；

3）服务器再校验此口令，若此OTP被认证成功，则客户被授权访问服务器

1）一次性口令认证

方案3：时间同步

◆ 采取用户登录的系统时间作为随机数，对时间准确度把握要求高（分钟级）。数据单向也就是只需要用户向服务器发送口令而不需要服务器的反馈信息；



2）基于USB Key的身份认知

USB Key是一种USB接口的硬件设备，它内置单片机或智能卡芯片，可以存储用户的密钥或数字证书，利用USBKey内置的密码算法实现对用户身份的认证，目前在电子政务、网上银行等广泛应用



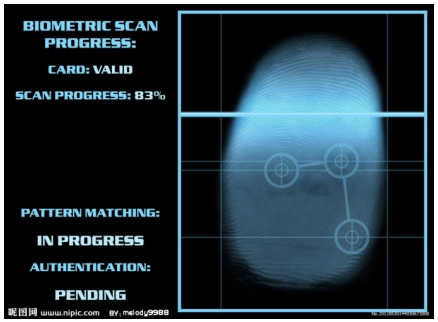




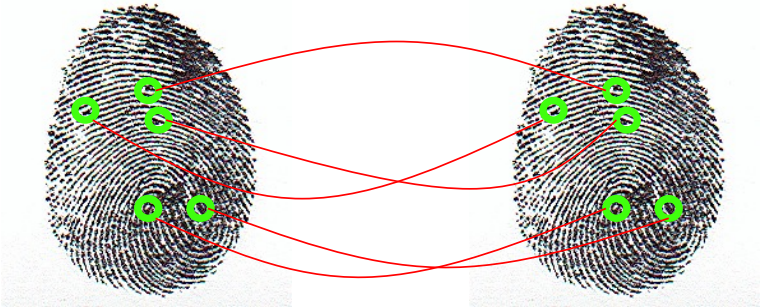
3）基于生物特征的身份认证

生物特征是指唯一的可以测量或可自动识别和验证的生理特征或行为方式。生物特征分为身体特征和行为特征两类。**身体特征**包括：指纹、掌型、视网膜、虹膜、人体气味、脸型、手的血管和DNA等；**行为特征**包括：签名、声音、行走步态等。



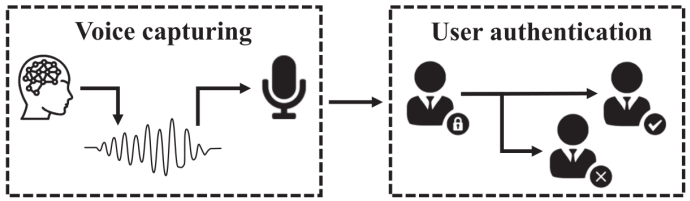




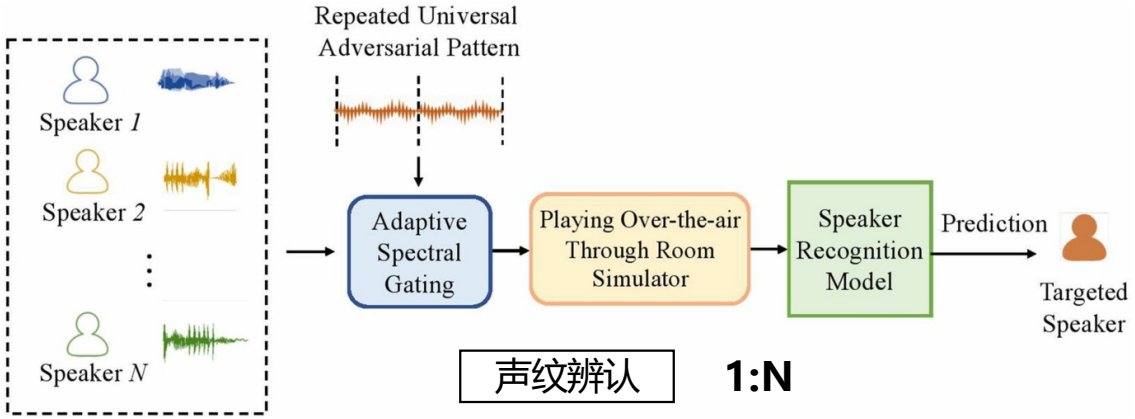


3）基于生物特征的身份认证

声纹识别是根据说话人的**声波特性**进行身份辨识的服务，**与口音和语言无关**



声纹鉴定 1:1



声纹辨认 1:N

是否是来自已注册说话人

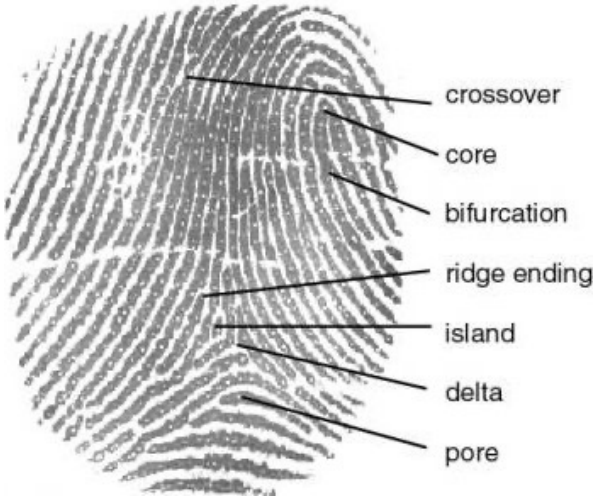
掌型与指纹识别





指纹套



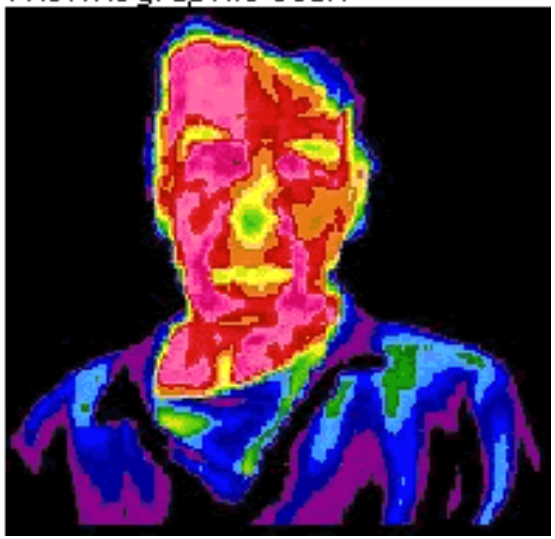


如果没有任何保护措施，基于指纹的身份认证系统同样对重发攻击没有免疫力，攻击者能够简单地绕过指纹采样设备，直接将一个比特串发往认证服务器，从而假冒合法用户的身份访问网络资源。因此，象密钥一样，指纹认证中的指纹数据必须得到保护

G. L. LIN, H. M. SUN, T. H. WANG. Attacks and Solutions on Strong-Password Authentication [J]. IEICE Trans. Commun., 2001, E84-B(9): 2622-2627.

生物特征介绍（续）

Thermographic scan



http://www.biofs.com/eng/s1.php



http://www.cs.bham.ac.uk/~mdr/teaching/modules03/security/students/SS3/handout/index.html

视网膜纹路识别



http://www.arcent.army.mil/cflcc_today/2005/january/iraqi_election.asp



http://www.eyes.co.nz/eye_care.html

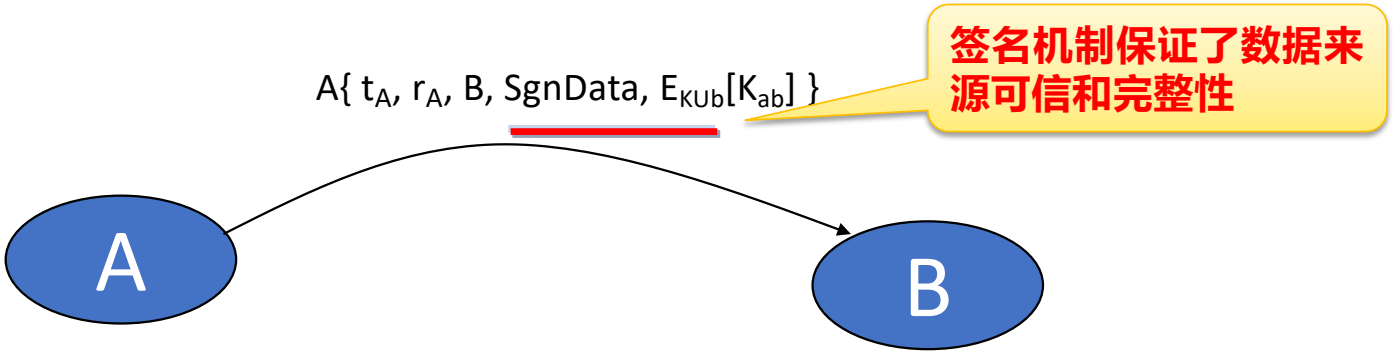
4）对称加密认证-握手协议



- **简单，可以在单机系统上使用**
- **但在网络上很不安全**
  - 易被重放攻击
  - Bob 必须知道Alice的密码

4）非对称加密认证模型

- **单向认证(One-Way Authentication)**



t_A: 时间戳

r_A : Nonce， 用于监测报文重发的一个随机序列值

SgnData: 签名数据

$E_{KUb}[K_{ab}]$: 用B的公钥加密的会话密钥

B 收到数据以后，用A的公钥验证数字签名，从而确信的确是从A 发送来的;
通过t_A验证时效性，通过r_A验证没有重发

身份认证总结

所知

- 密码、口令等

所有

- 动态口令设备、IC卡、电子钥匙(Usb Key)等

所是

- 指纹、人脸、笔迹、声音、虹膜、DNA等

基于口令的身份认证

基于USB Key的身份认证

基于生物特征的身份认证

基于协议的身份认证

零知识证明协议

Contents 内容



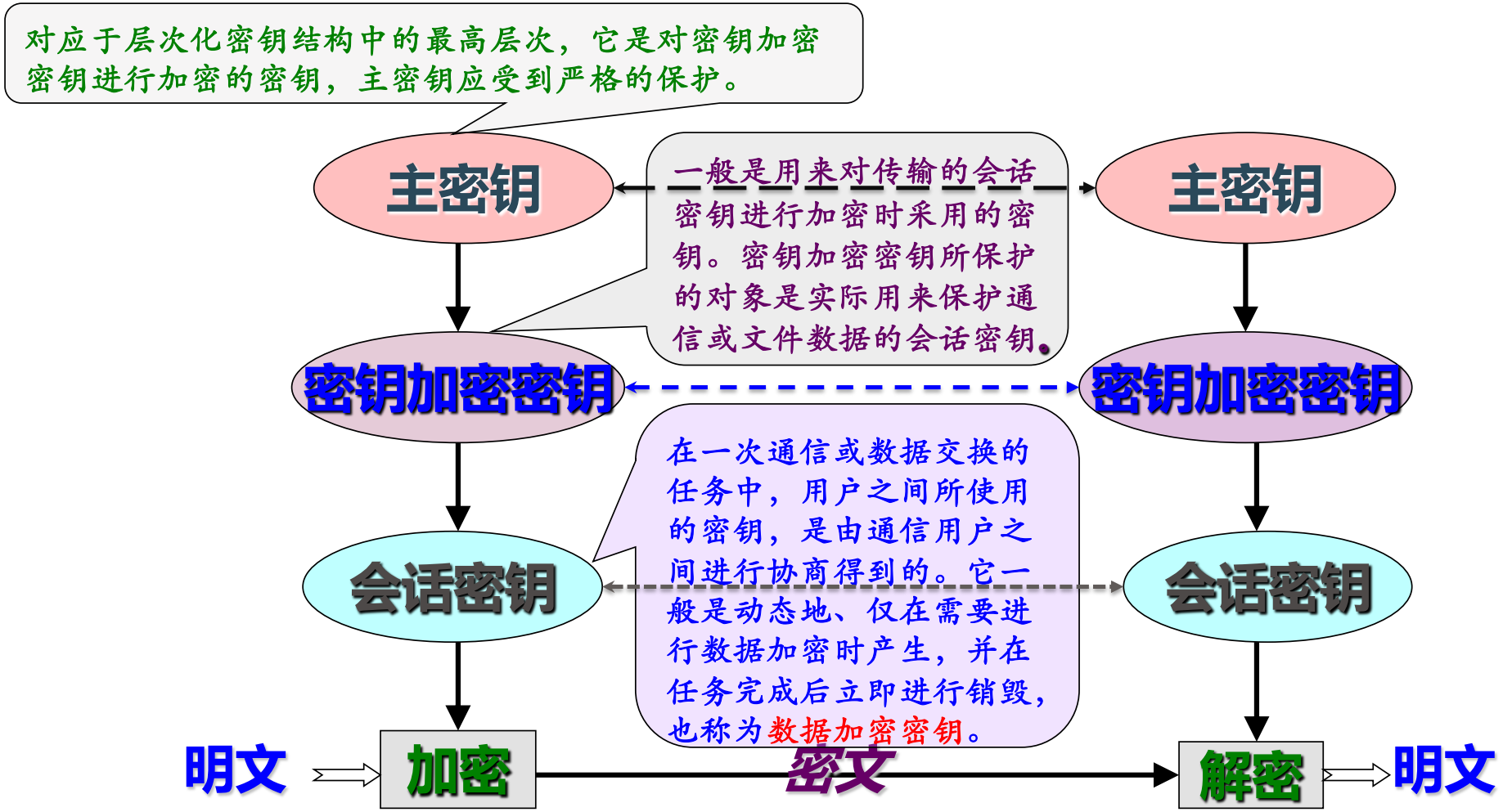
1 身份认证

2 对称密钥协商

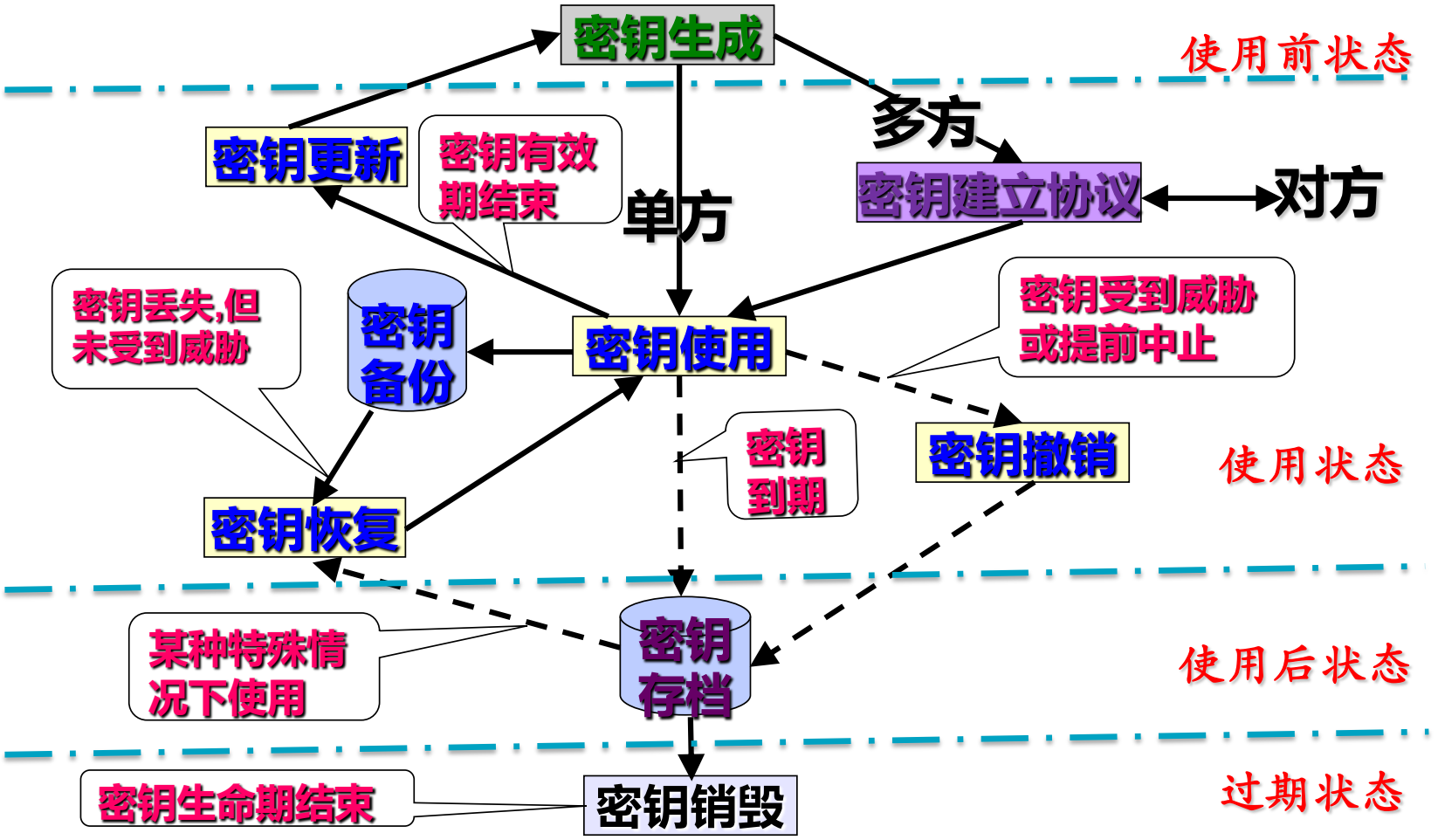
3 非对称密钥协商

4 门限密码

2.1 密钥的层次结构


对应于层次化密钥结构中的最高层次，它是对密钥加密密钥进行加密的密钥，主密钥应受到严格的保护。
主密钥
一般是用来对传输的会话密钥进行加密时采用的密钥。密钥加密密钥所保护的对象是实际用来保护通信或文件数据的会话密钥。
主密钥
密钥加密密钥
密钥加密密钥
在一次通信或数据交换的任务中，用户之间所使用的密钥，是由通信用户之间进行协商得到的。它一般是动态地、仅在需要进行数据加密时产生，并在任务完成后立即进行销毁，也称为数据加密密钥。
会话密钥
会话密钥
明文
加密
密文
解密
明文

2.1 密钥的生命周期


密钥生成
使用前状态
密钥更新
密钥有效期结束
单方
多方
密钥建立协议
对方
密钥丢失,但未受到威胁
密钥备份
密钥使用
密钥受到威胁或提前中止
密钥到期
密钥撤销
使用状态
密钥恢复
某种特殊情况下使用
密钥存档
使用后状态
密钥生命期结束
密钥销毁
过期状态

2.2 密钥分配/协商

- 密钥分配就是一种机制，通过这种机制，通信双方中的一方或密钥分配中心选取一个秘密密钥，然后将其传送给通信双方中的另一方。

目的

- 密钥分配技术是在不让其他人（除密钥分配中心）*看到*密钥的情况下将一个密钥传递给希望交换数据的双方的方法。

安全

- 为提高密钥的安全性，必须时常更新密钥，密码系统的强度依赖于密钥分配技术。

重要

2.2 密钥分配-基本方法

- ✓ 如果A、B事先已拥有相同的密钥，则其中一方选取新密钥后，用已有的密钥加密新密钥并发送给另一方。

事先设置

- ✓ 如果A和B与第三方C分别有一保密信道，则C为A、B选取新密钥后，其中一方把新密钥安全传送给另一方。

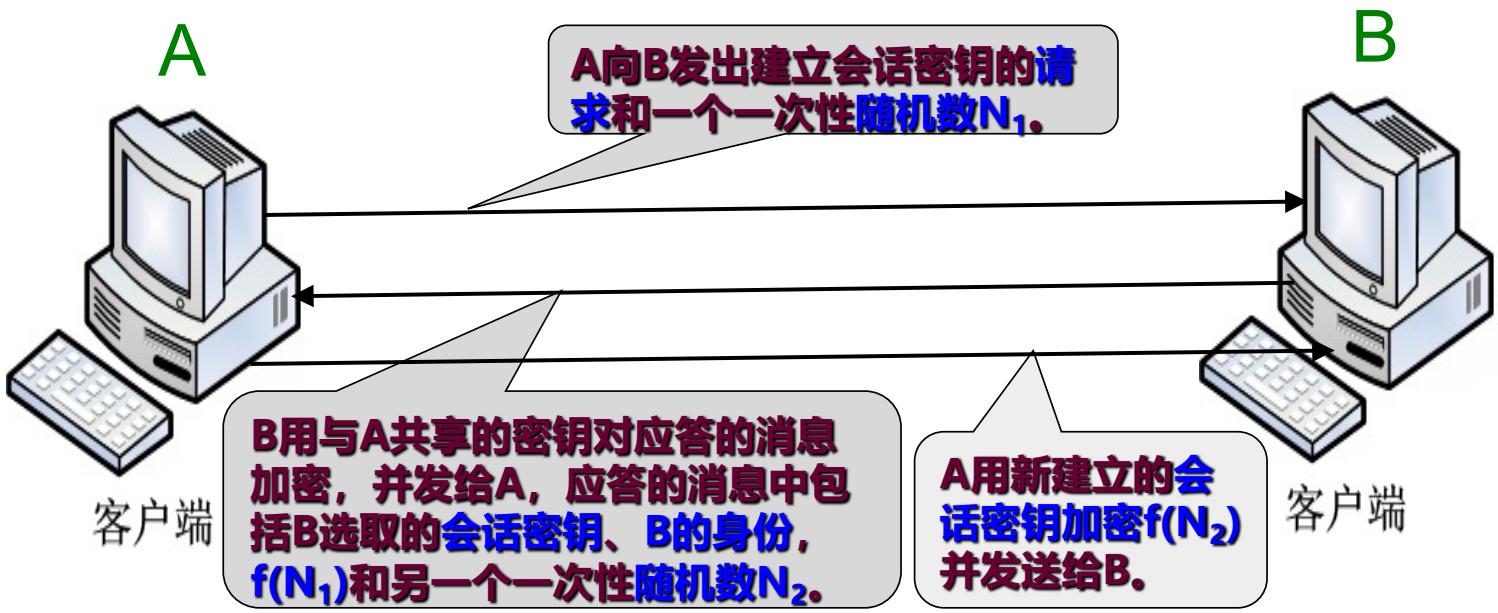
分配中心

- ✓ 如果A、B事先有自己的私钥，则其中一方选取新密钥，利用公钥密码技术实现新密钥安全传送。

基于公钥

2.2 无中心的密钥分配模式

前提条件：通信双方有共享密钥。



问题：为什么分配密钥需要随机数？

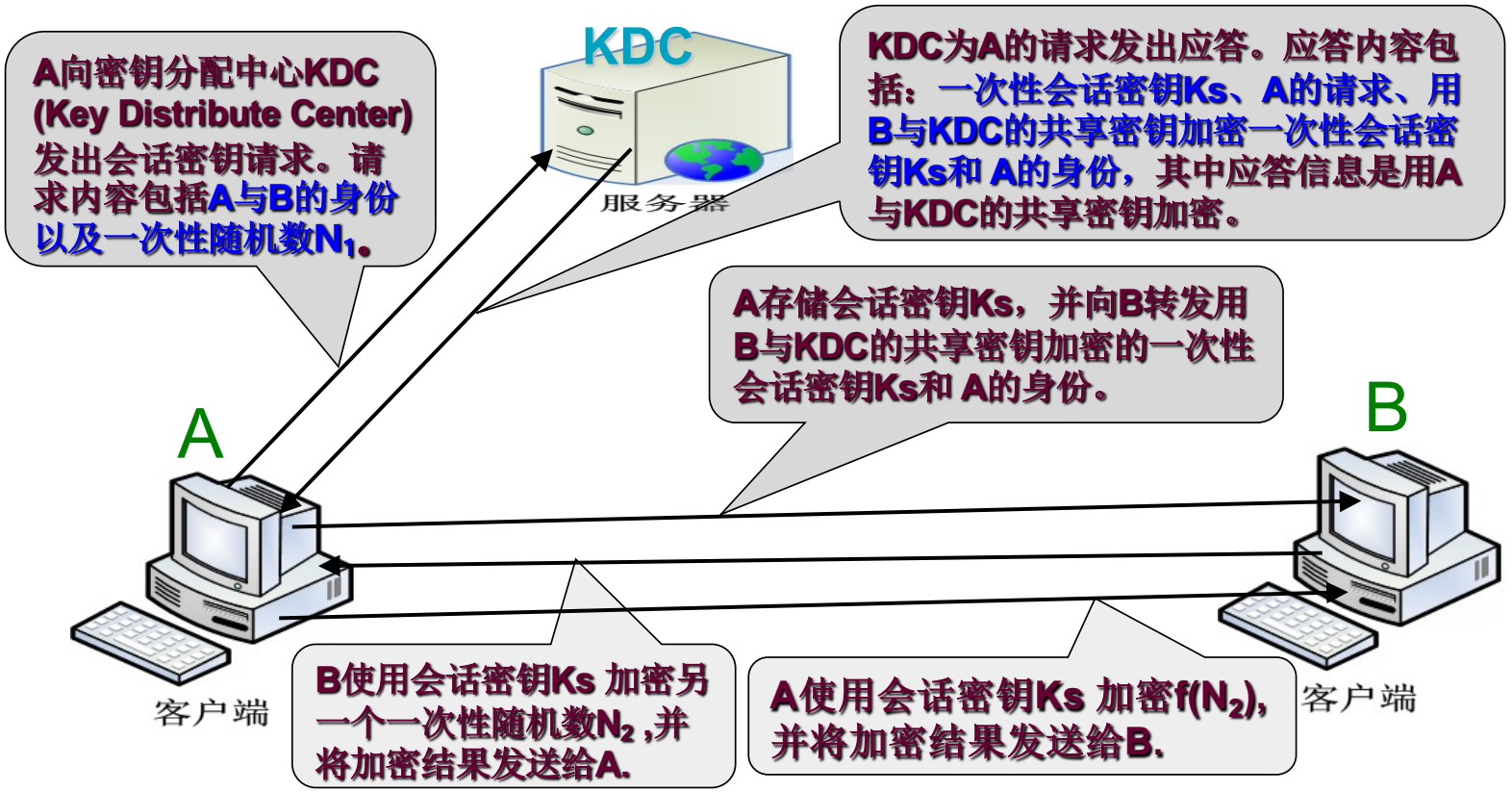
2.2 密钥分配中心模式

建立一个负责为用户分配密钥的密钥分配中心，这时每一用户必须和密钥分配中心有一个共享密钥，称为主密钥。通过主密钥分配给一对用户的密钥称为会话密钥，用于这一对用户之间的保密通信。通信完成后，会话密钥即被销毁。

如果用户数为n，则会话密钥数为n(n-1)/2，但主密钥数却只需n个。

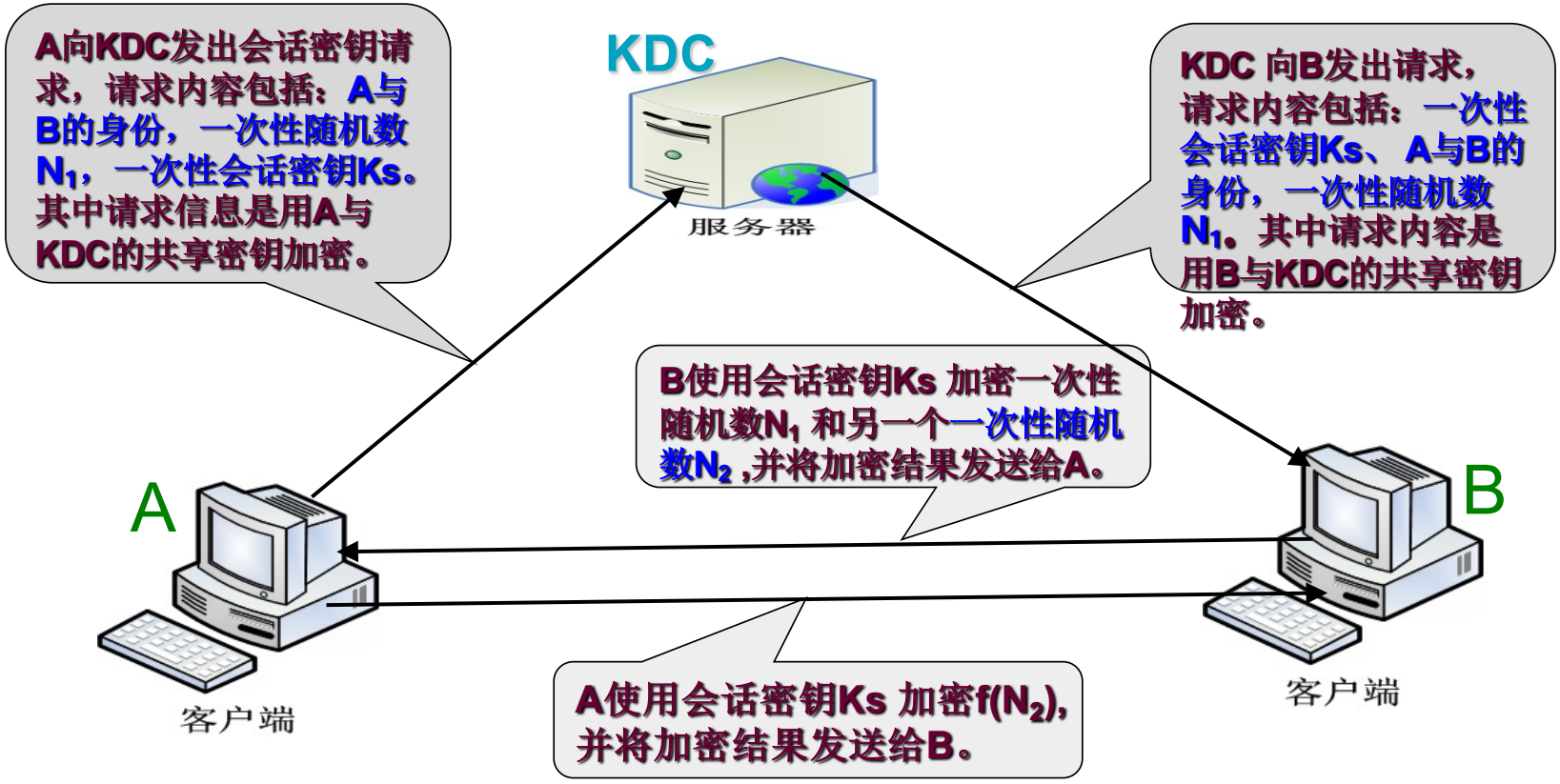
2.2 密钥分配中心模式(KDC生成)

前提条件：密钥分配中心与每个用户之间有共享密钥。



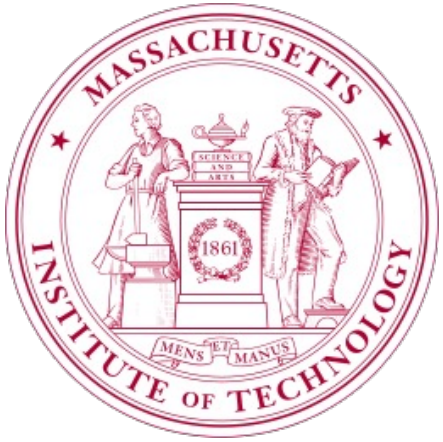
2.2 密钥分配中心模式(发起方生成)

前提条件：密钥分配中心与每个用户之间有共享密钥。



身份认证——Kerberos认证

Kerberos was developed as the authentication engine for MIT's Project Athena in 1983. Released as Open Source in 1987, it became an IETF standard in 1993.

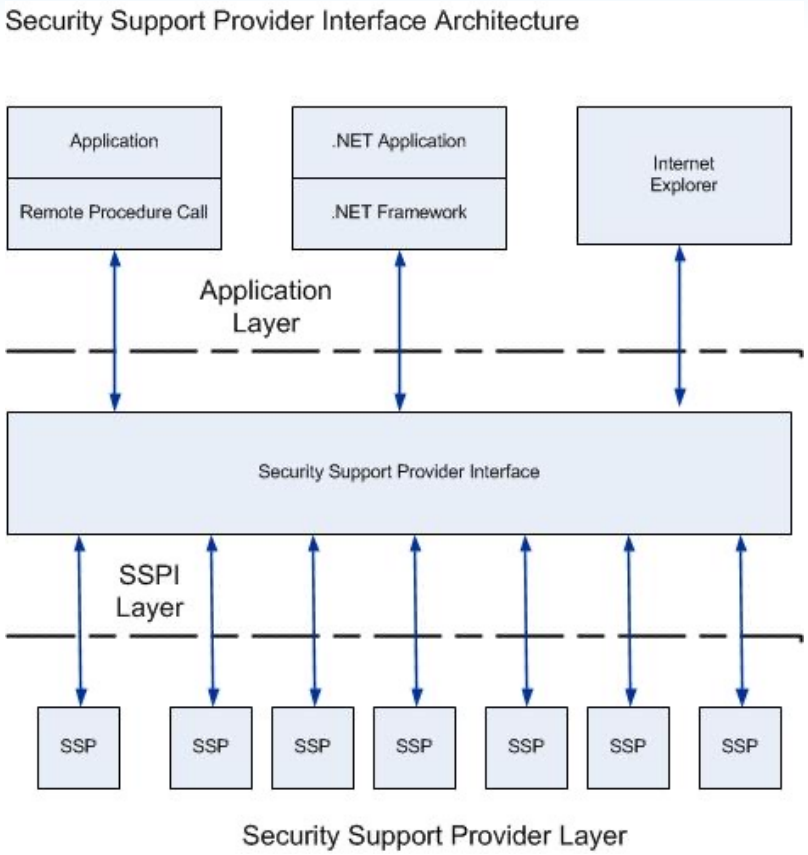


- Authen
- Accoun
- Audit

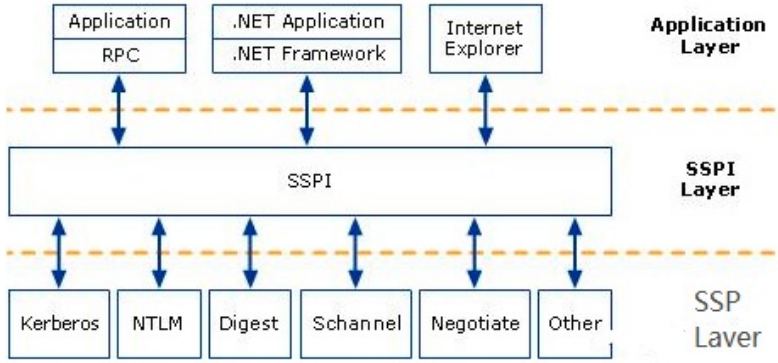


http://www.kerberos.org/

Security Support Provider



SSP（Security Support Provider），又名Security Package，实际就是一个个DLL，用来实现身份认证，例如：NTLM、Kerberos、Negotiate、Secure Channel (S-channel) 、 Digest 、 Credential (CredSSP)等。



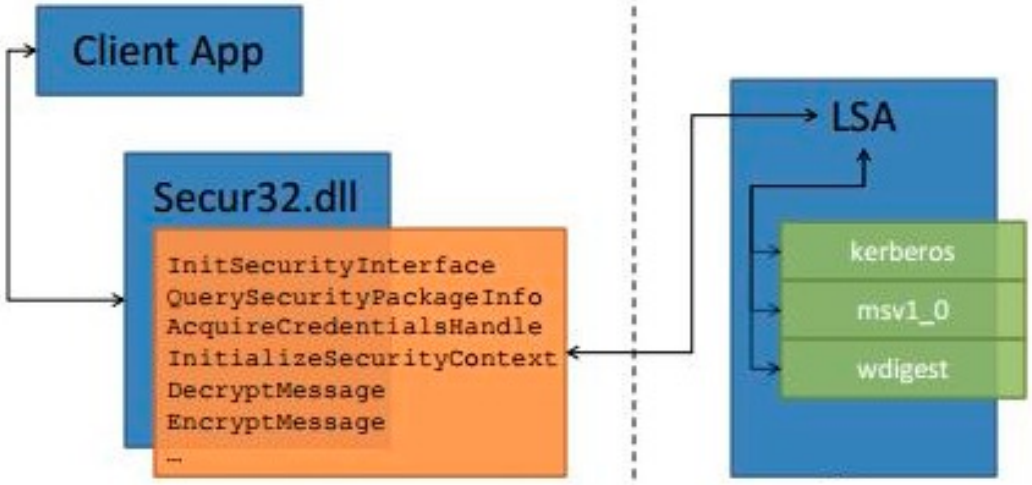
Windows、Linux、Mac这3大主流操作系统均支持Kerberos协议

https://docs.microsoft.com/en-us/previous-versions/windows/it-pro/windows-server-2012-R2-and-2012/dn751052(v=ws.11)?redirectedfrom=MSDNDocs

Windows 2022/2019/2016 Server的身份认证

操作系统	特征	说明
Active Directory域中的身份验证	Kerberos	Microsoft Windows Server 操作系统可实现 Kerberos 版本 5 身份验证协议和对公用密钥身份验证的扩展。 Kerberos 身份验证客户端可作为安全支持提供程序 (SSP) 实现，并可以通过安全支持提供程序接口 (SSPI) 进行访问。 初始用户身份验证与 Winlogon 单个登录体系结构相集成。 Kerberos 密钥发行中心 (KDC) 与在域控制器上运行的其他 Windows Server 安全服务相集成。 KDC 使用域的 Active Directory 目录服务数据库作为安全帐户数据库。 Active Directory 是默认 Kerberos 实现所必需的。 有关更多资源，请参阅 Kerberos 身份验证概述。
Web 上的安全身份验证	Schannel 安全支持提供程序中实现的 TLS/SSL	传输层安全 (TLS) 协议版本 1.0、1.1 和 1.2、安全套接字层 (SSL) 协议版本 2.0 和 3.0、数据报传输层安全协议版本 1.0 和专用通信传输 (PCT) 协议版本 1.0 基于公钥加密。 安全通道 (Schannel) 提供程序身份验证协议套件提供这些协议。 所有 Schannel 协议使用客户端和服务器模型。 有关其他资源，请参阅 TLS - SSL (Schannel SSP) 概述。
对 Web 服务或应用程序进行身份验证	Windows 集成身份验证摘要式身份验证	有关其他资源，请参阅集成 Windows 身份验证和摘要式身份验证，以及高级摘要式身份验证。
对旧版应用程序进行身份验证	NTLM	NTLM 是一种质询-响应式身份验证协议。除了身份验证之外，NTLM 协议还选择性地提供会话安全性，特别是通过 NTLM 中的签名和密封功能实现消息完整性和保密性。 有关更多资源，请参阅 NTLM 概述。
利用多重身份验证	智能卡支持生物识别支持	智能卡是为任务（如客户端身份验证、登录到域、代码签名和保护电子邮件）提供安全解决方案的防篡改且便携式的方式。 生物识别依赖于测量个人的不变物理特征以便对此人进行唯一标识。 指纹是最常用的生物识别特征，数以百万计的指纹生物识别设备都嵌入到个人计算机和外围设备中。 有关其他资源，请参阅 智能卡技术参考。
提供本地管理、存储和重新使用凭据	凭据管理本地安全机构密码	凭据管理Windows确保安全地存储凭据。 通过应用程序或网站在安全桌面上收集凭据（适用于本地或域访问），以便每次访问资源时都能出现正确的凭据。
扩展对旧版系统的现代身份验证保护	身份验证的扩展保护	该功能可通过使用集成的 Windows 身份验证 (IWA) 增强对网络连接进行身份验证时的凭据保护和处理。

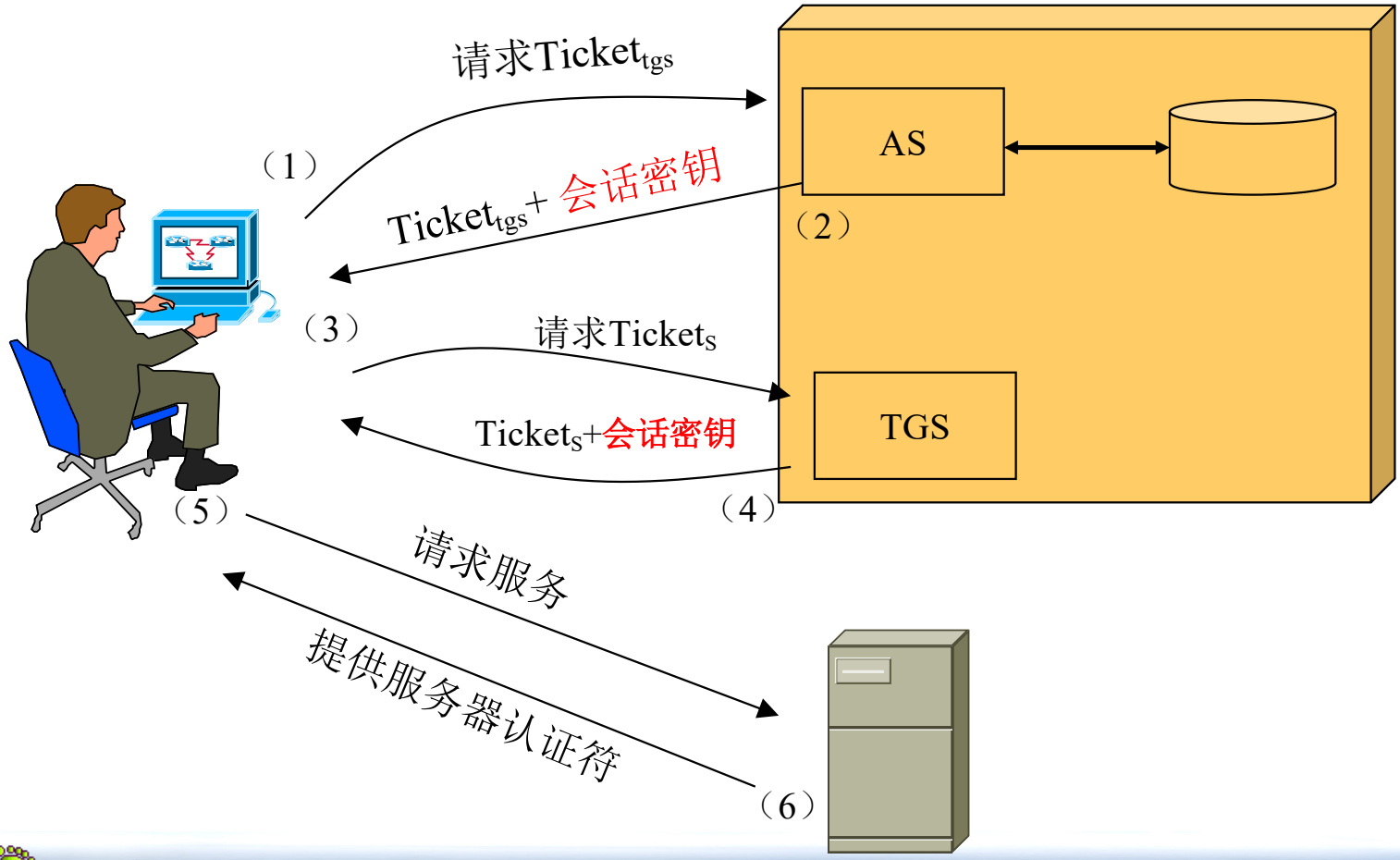
身份认证——Kerberos认证



LSA（Local Security Authority）用于身份认证，常见进程为lsass.exe；但LSA是可扩展的，在系统启动的时候SSP会被加载到进程lsass.exe中。这相当于我们可以自定义一个dll，在系统启动的时候被加载到进程lsass.exe

Client APP是我们自定义的DLL，通过Secur32.dll可以调用“credential capture API”来获取LSA的信息。

Kerberos v4 的认证过程



Kerberos报文交换第一轮：获取票据许可票据

Step (1) 用户请求票据许可票据

- 用户请求票据许可票据的工作在登录工作站时进行。
- 登录时用户被要求输入用户名，输入后系统会向认证服务器AS以明文方式发送一条包含用户和TGS服务两者名字的请求。

$C \rightarrow AS : ID_C \| ID_{tgs} \| TS_1$

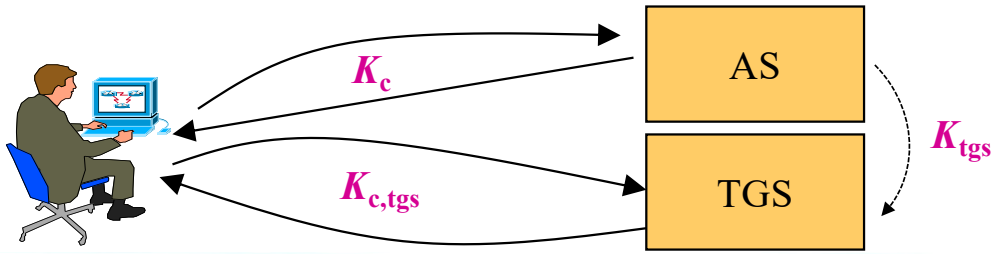
Kerberos报文交换第一轮：获取票据许可票据

Step (2) AS发放票据许可票据和会话密钥

认证服务器检查用户如果有效，随机产生一个用户和TGS之间的会话密钥$K_{c,tgs}$，然后创建一个票据许可票据$Ticket_{tgs}$（票据许可票据使用K_{tgs}加密）。认证服务器向用户发送票据许可票据和会话密钥$K_{c,tgs}$，发送的消息用只有用户和AS知道的K_c来加密（K_c的值基于用户的密码）。

$$AS \rightarrow C : E_{Kc}[K_{c,tgs} \| ID_{tgs} \| TS_2 \| Lifetime_2 \| Ticket_{tgs}]$$

$$Ticket_{tgs} = E_{Ktgs}[K_{c,tgs} \| ID_C \| AD_C \| ID_{tgs} \| TS_2 \| Lifetime_2]$$



Kerberos报文交换第二轮：获取访问票据

Step (3) C请求服务器票据

用户工作站收到AS回应后，要求用户输入密码，将密码转化为DES密钥K_c，然后将AS发回的信息解开，将$Ticket_{tgs}$和$K_{c,tgs}$保存用于以后的通信，为了安全性用户密码和密钥K_c被删掉。

一个票据只能申请一个特定的服务，所以用户必须为每一个服务器申请新的票据，用户可以从TGS处得到票据$Ticket_S$。

用户首先向TGS发出申请服务器票据的请求。请求信息中包含TGS服务器的名字，上一步中得到的请求TGS服务的加密票据$Ticket_{tgs}$，还有用会话密钥$K_{c,tgs}$加密过的Authenticator信息。

$C \rightarrow TGS: ID_{tgs} \| Ticket_{tgs} \| Authenticator_c$

$Authenticator_c = E_{Kc,tgs}[ID_c \| AD_c \| TS_3]$

$Ticket_{tgs} = E_{K_{tgs}}[K_{c,tgs} \| ID_C \| AD_C \| ID_{tgs} \| TS_2 \| Lifetime_2]$

$AS \rightarrow C : E_{Kc}[K_{c,tgs} \| ID_{tgs} \| TS_2 \| Lifetime_2 \| Ticket_{tgs}]$

Kerberos报文交换第二轮：获取访问票据

Step (4) TGS发放服务器票据和会话密钥

TGS收到请求后，用密钥K_{tgs}和会话密钥$K_{c,tgs}$分别解开$Ticket_{tgs}$和$Authenticator_c$，根据两者的信息鉴定用户身份是否有效。如果有效，TGS生成用于C和S之间通信的会话密钥$K_{c,s}$，并生成C申请S服务的票据$Ticket_s$，其中包含C和S的名字、C的网络地址、当前时间、有效时间和刚才产生的会话密钥$K_{c,s}$。

TGS最后将加密后的票据Tickets和会话密钥$K_{c,s}$用用户和TGS之间的会话密钥$K_{c,tgs}$加密后发送给用户。用户C得到回答后，用$K_{c,tgs}$解密，得到所请求的票据和会话密钥。

$$TGS \rightarrow C : E_{Kc,tgs}[K_{C,S} \,||\, ID_S \,||\, TS_4 \,||\, Ticket_S]$$

$$\mathbf{Ticket_S = E_{Ks}[\,K_{C,S}||ID_C||AD_C||\,ID_S||TS_4||Lifetime_4]}$$

Ks是TGS服务器和Server之间的共享密钥

$$C \rightarrow TGS: ID_{tgs} \,||\, Ticket_{tgs} \,||\, Authenticator_c$$

$$Ticket_{tgs} = E_{Ktgs}[K_{c,tgs}||\, ID_C||\, AD_C||\, ID_{tgs} \,||\, TS_2 \,||\, Lifetime_2]$$

$$Authenticator_c = E_{Kc,tgs}[ID_c||AD_c||TS_3]$$

Kerberos报文交换第三轮：获取服务

Step (5) 工作站将票据和认证符发给服务器

$C \rightarrow S: Ticket_S \,||\, Authenticator_c$

$\mathbf{Ticket_S = E_{Ks}\,[K_{c,s}||ID_c||AD_c||ID_s||TS_4||Lifetime_4]}$

$Authenticator_c = E_{Kc,s}[ID_c||AD_c||TS_5]$

Step (6) 服务器验证票据$Ticket_S$和认证符中的匹配，然后许可访问服务。如果需要双向认证，服务器返回一个认证符

$S \rightarrow C : E_{Kc,s}\,[TS_5+1]$

Contents 内容



1 身份认证

2 对称密钥协商

3 非对称密钥协商

4 门限密码

3.1 什么是PKI

PKI（Public Key Infrastructure）是一个用公钥概念与技术来实施和提供安全服务的具有普适性的安全基础设施

普适性：只要遵循必要的原则，就能使用提供的服务。比如：网络基础设施、电力基础设施等。

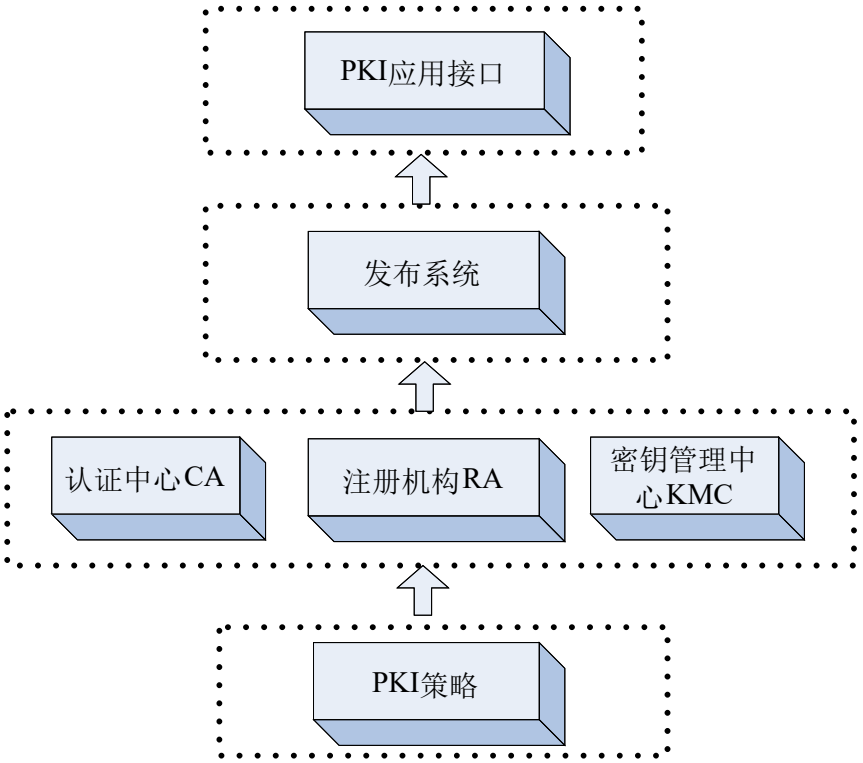
安全服务：公钥密码的功能、密码的功能等。

3.1 PKI作用

- **认证：采用数字签名技术，签名作用于相应的数据之上**
  - 被认证的数据 —— 数据源认证服务
  - 用户发送的远程请求 —— 身份认证服务
  - 远程设备生成的challenge信息 —— 身份认证
- **完整性：PKI采用了两种技术**
  - 数字签名：既可以是实体认证，也可以是数据完整性
  - MAC(消息认证码)：如DES-CBC-MAC或者HMAC-MD5
- **保密性：用公钥分发随机密钥，然后用随机密钥对数据加密**
- **不可否认：**
  - 发送方的不可否认 —— 数字签名
- **其他：性能问题、使用方式问题等**

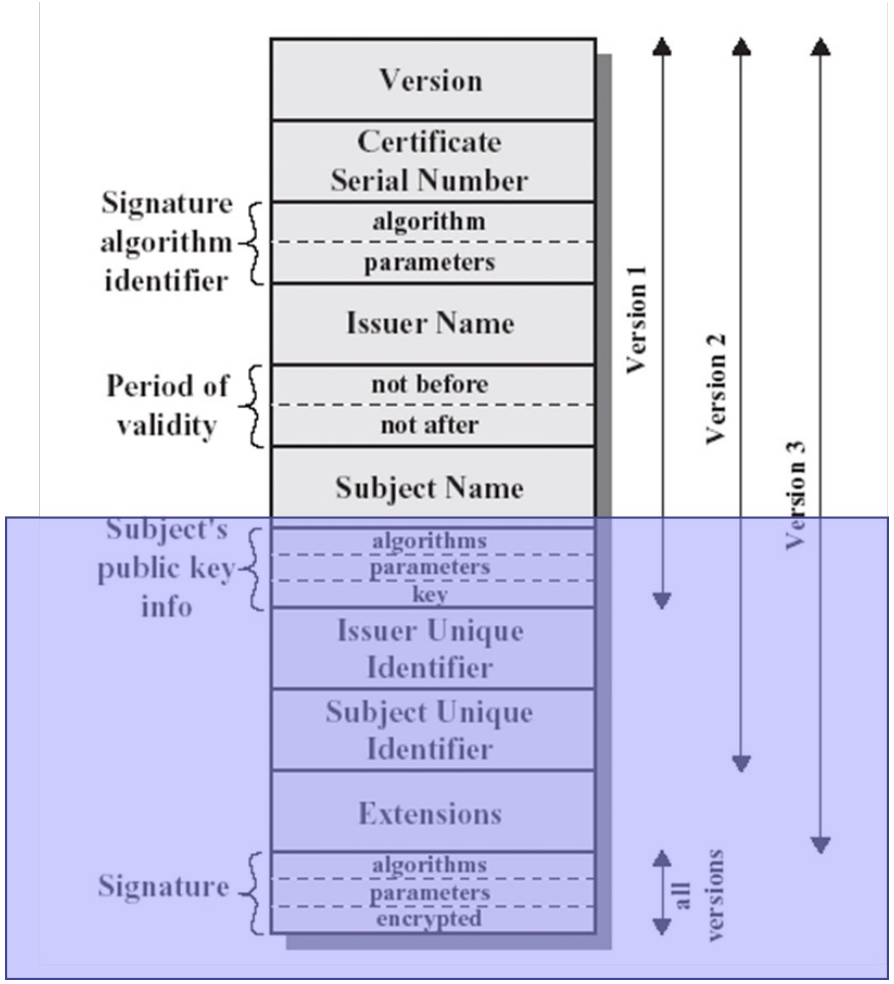
3.2 PKI原理

- 原理：数字证书＋权威认证
- 基本组成：



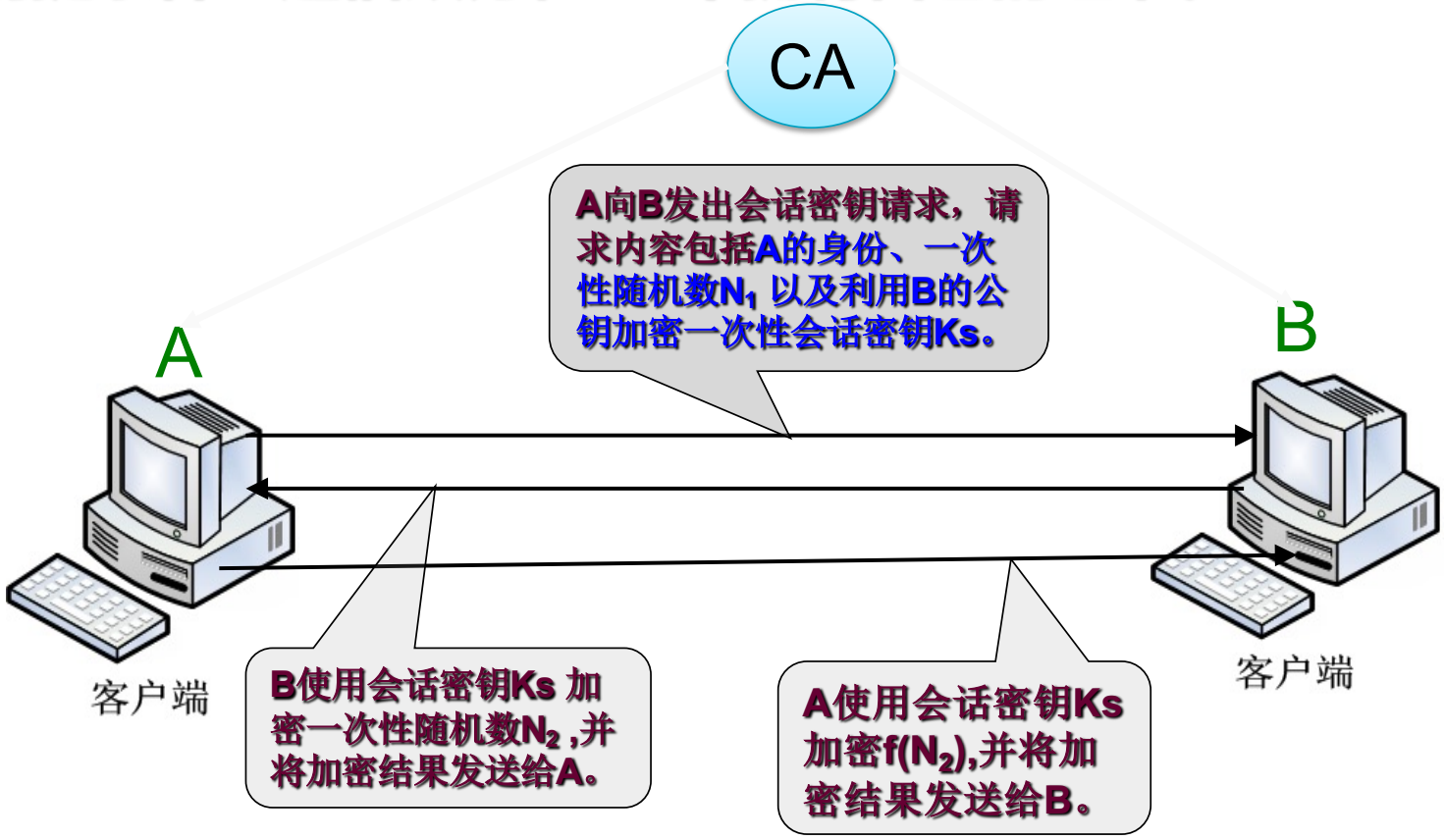
3.2 数字证书的结构

- 版本：用于识别证书版本号，版本号可以是V1、V2和V3，目前常用的版本是V3
- 序列号：是由CA分配给证书的唯一的数字型标识符。当证书被取消时，将此证书的序列号放入由CA签发的CRL中
- 签名算法标识：用来标识对证书进行签名的算法和算法所需的参数。协议规定，这个算法同证书格式中出现的签名算法必须是同一个算法
- 签发者：为CA的名称
- 有效期：是一对日期——起始日期和结束日期，证书在这段日期之内有效
- 主体：为证书持有者的名称
- 主体的公开密钥：包括算法名称，需要的参数和公开密钥
- 可选项：签发者唯一标识、主体唯一标识和扩展项都是可选项，可根据具体需求进行选择

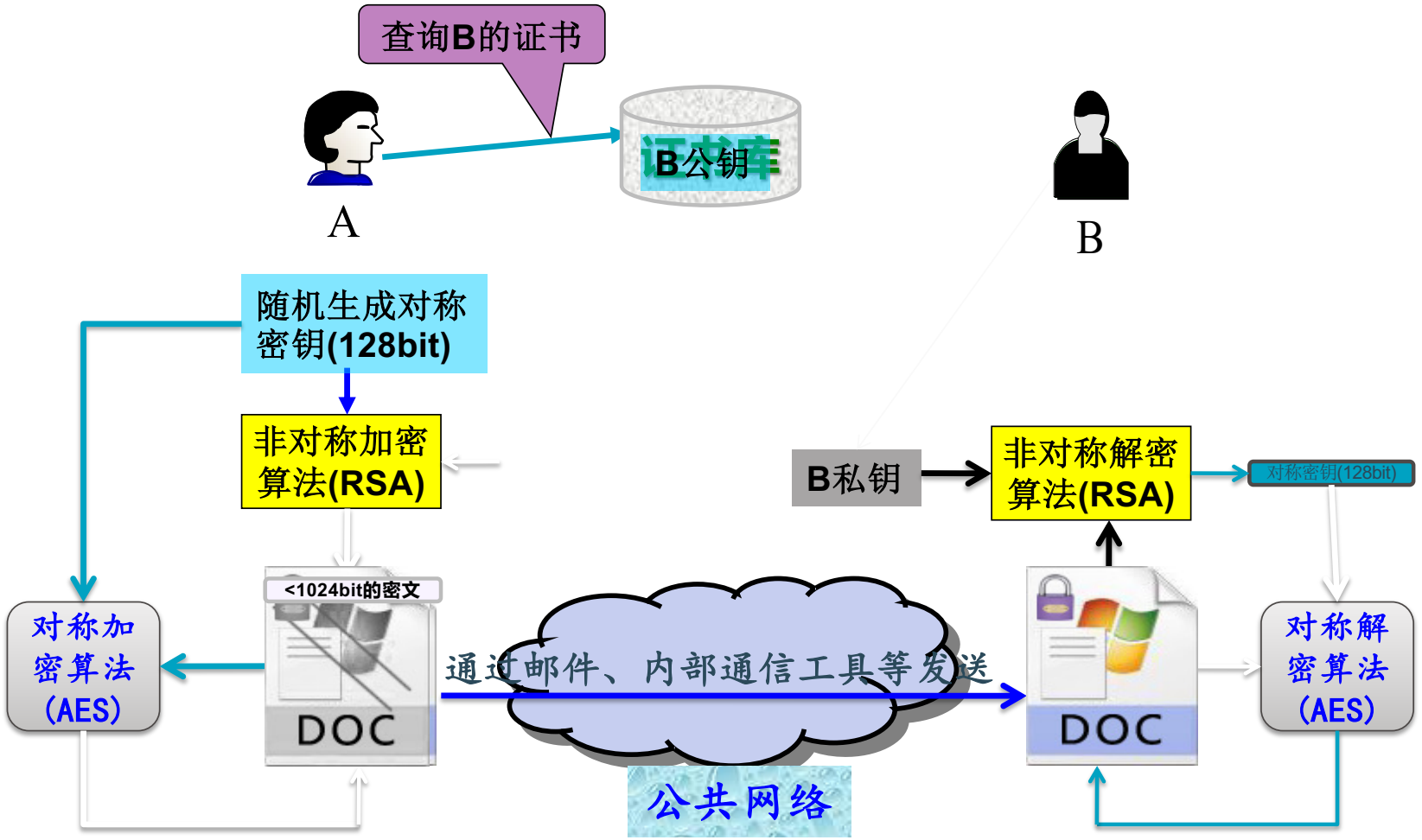


3.3 基于公钥密钥分配

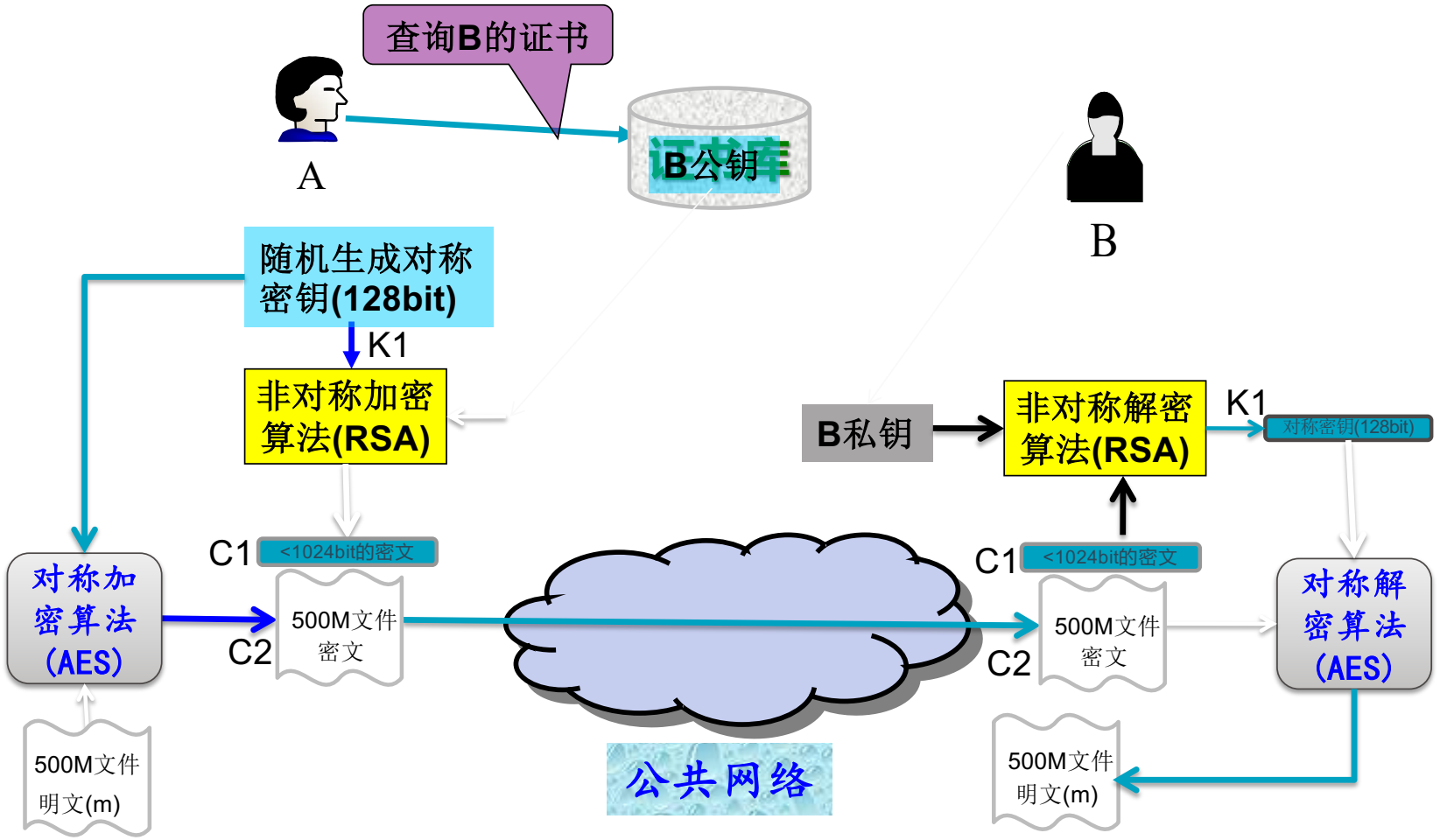
前提条件：通信双方在CA中拥有自己的证书。



3.3 举例说明文件加密传送(混合密码)



3.3 举例说明文件加密传送(混合密码)

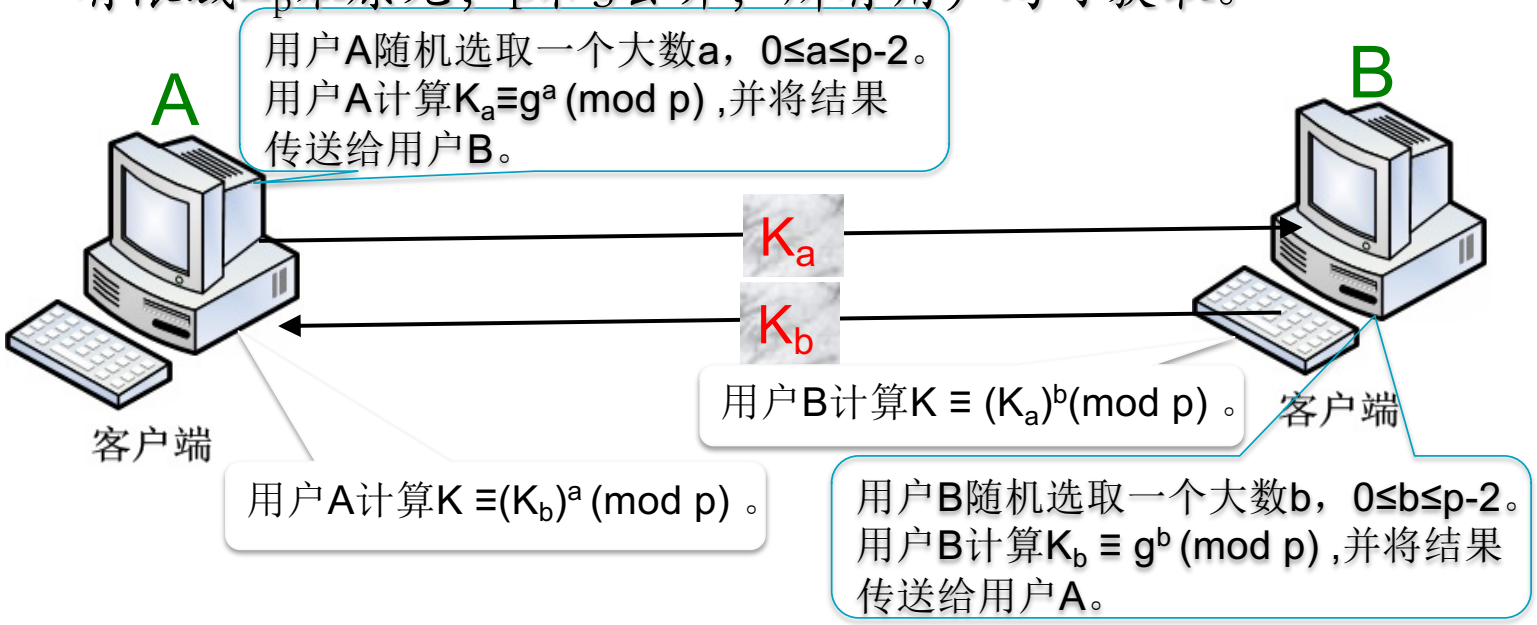


3.4 密钥协商3

- 密钥协商是保密通信双方（或更多方）通过公开信道的通信来共同形成秘密密钥的过程。一个密钥协商方案中，密钥的值是某个函数值，其输入量由两个成员（或更多方）提供。
- 密钥协商的结果是：参与协商的双方（或更多方）都将得到相同的密钥，同时，所得到的密钥对于其他任何方都是不可知的。

3.4 Diffie-Hellman密钥交换方案

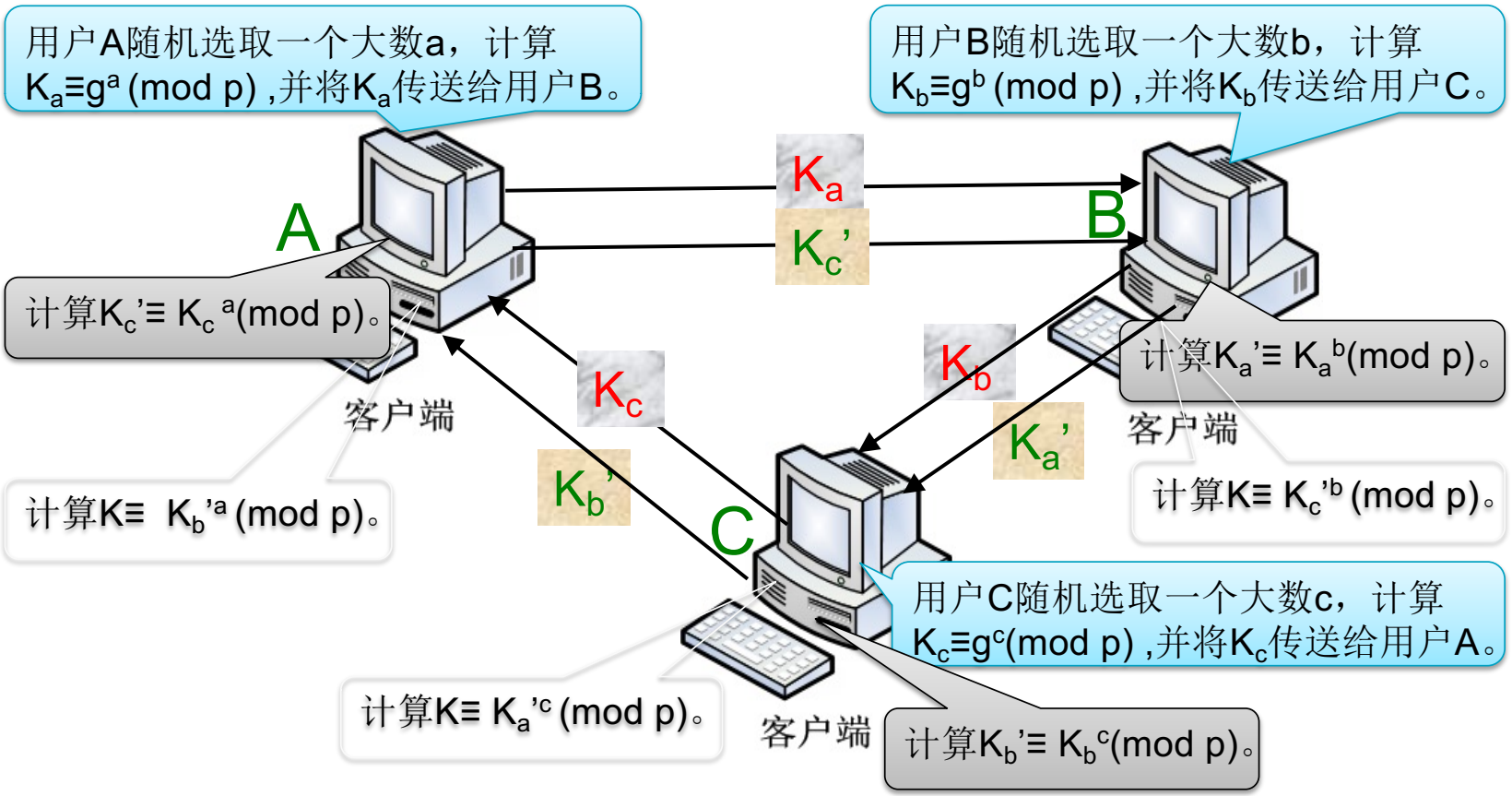
前提条件： 设p是一个安全的大素数，$g \in Z_p$是有限域Z_p本原元，p和g公开，所有用户均可获取。



用户A和用户B各自计算生成共同的会话密钥K。

这是因为： $K \equiv (K_b)^a \equiv (g^b)^a \equiv g^{ab} \equiv (g^a)^b \equiv (K_a)^b$。

3.4 密钥协商-Diffie-Hellman方案(扩展)



显然，秘密密钥k 等于g^{abc} mod p，除了他们三人外，没有别的人能计算出k值。

Contents 内容



1 身份认证

2 对称密钥协商

3 非对称密钥协商

4 门限密码

4.1 秘密共享方案引言

- 将一个秘密分为多份并分配给多个参与者，默写指定的参与者自己可以恢复密码，这些子集构成的集合成为方案的访问结构。不在访问结构的中的参与者自己不能得到秘密的任何信息。

- 如果简单用一个秘密共享方案分享一个加密方案的解密密钥或一个签名方案的签名密钥，解密或签名时需要恢复密钥，此时密钥将被泄露，因此引入(t, n)门限秘密共享方案(t≤n)。

4.1 秘密共享方案

(t, n)门限秘密共享方案的定义：

- 消息空间M
- 分享算法$s_1, \ldots s_{n-1}$⬅Share(t, n, s)，为一个随机算法
- 输入为门限值t、份额数量n、秘密s∈M
- 输出为n个秘密份额
- 消息空间上重构算法s:=Reconstruct($s_{i_1}, \ldots s_{i_t}$)为一个确定性算法。
- 输入t个秘密份额$s_{i_1}, \ldots s_{i_t} \in M$，输出秘密s∈M

4.1 秘密共享方案

- (t, n)门限秘密共享方案应满足，t个份额可以恢复秘密，少于t个份额无法获得关于秘密的任何信息，这是信息论意义下的安全性。
- 对于任何秘密s，当给定的秘密份额少于t个时，这些份额的概率分布与秘密无关，不会泄露秘密的任何信息，此时称这样的门限秘密共享方案是（完美）安全的。

4.2 Z_p上的(n,n)门限秘密共享方案

- 分享算法：

输入份额数量n≥2、秘密s∈ Z_p, 均匀随机选取$s_1, \dots s_{n-1}$ $\leftarrow_R Z_p$， 计算 $s_n = \left(s - \sum_{i=1}^{n-1} s_i\right) mod\ p$, 输出秘密份额$s_1, \dots s_n$。

- 重构算法：

输入n个秘密份额$s_1, \dots s_n$， 计算$s = \sum_{i=1}^{n} s_i\ mod\ p$， 输出s。

4.3 Shamir(t,n)门限秘密共享方案

- 分享算法：

输入门限值t、份额数量n、秘密s∈ Z_p，均匀随机选取$u_j \leftarrow_R Z_p (j = 1, \dots t-1)$，令$u_0$=s，构造t-1次多项式$a(x) = u_0 + u_1 x + \cdots + u_{t-1} x^{t-1} \bmod p$，并计算$s_i = a(i)$ (i=1, ⋯, n)，输出n个秘密份额$s_1, \dots s_n$。

- 重构算法：

对于任意t个秘密份额，记它们的指标集合Q=$\{i_1, \dots, i_t\}$，根据拉格朗日插值法，恢复秘密s，即

$s = \sum_{i \in Q} s_i \ \lambda_{Q,i} \bmod p$

其中$\lambda_{Q,i} = \prod_{j \in Q \setminus \{i\}} \frac{j}{j-i} \bmod p$

由于对于给定的n +1个点，对应于它们的次数都不超过n的拉格朗日多项式L只有一个，此时相当于使用t个点重构次数等于t-1的多项式a(x)，重构后令x=0，即可得到秘密的值。

4.3 Shamir(t,n)门限秘密共享方案

- 重构过程

如果任意t个参与者（t≤n）想要得到秘密s，可以构造如下的线性方程组，

假设t个参与者的秘密份额为$i_1, i_2, \cdots, i_t$

$$a(i_1) = u_0 + u_1 i_1 + \cdots + u_{t-1} {i_1}^{t-1} \bmod p$$
$$a(i_2) = u_0 + u_1 i_2 + \cdots + u_{t-1} {i_2}^{t-1} \bmod p$$
$$\cdots\cdots$$
$$a(i_t) = u_0 + u_1 i_t + \cdots + u_{t-1} {i_t}^{t-1} \bmod p$$

4.3 Shamir(t,n)门限秘密共享方案

- 因为t个秘密份额的取值均不相同，所以可由拉格朗日插值公式构造如下的多项式：$a(x)=\sum_{i\in Q} s_i \prod_{j\in Q\{i\}} \frac{x-j}{i-j} \lambda_{Q,i} \ mod\ p$
- 由于参与者仅需知道a(x)的常数项 $a(0)=u_0=s$，而无需知道整个多项式，所以令x＝0，即可得到$s=\sum_{i\in Q} s_i \ \lambda_{Q,i} \ \mathrm{mod}\ p$

  其中$\lambda_{Q,i}=\prod_{j\in Q\setminus\{i\}} \frac{j}{j-i} \ \mathrm{mod}\ p$

4.3 Shamir(t,n)门限秘密共享方案

方案的完善性分析：

- 如果K-1个参与者想获得秘密S，他们可构造出由K-1个方程构成的线性方程组，其中有K个未知量。
- 对GF(Q)中的任一值S0，可设F(0)＝S0，再加上上述的K-1个方程就可得到K个方程，并由拉格朗日插值公式得出F(X)。
- 因此对每一$S_0 \in GF(Q)$都有一个惟一的多项式满足1方程组所以已知K-1个子密钥得不到关于秘密S的任何信息，因此这个方案是完善的。

4.4 可验证的秘密共享

实际应用时还需要考虑主动攻击的情况，因此引入可验证的秘密共享方案，该方案可以抵御两种主动攻击：

- 分发者再分享协议中向一部分或者所有参与者发送不正确的秘密份额
- 参与者在重构协议中提交不正确的份额。

4.4 可验证的秘密共享

- 分享协议：

令G=<g>为p阶循环群，其中p为大素数，令$h \in_R <g> \backslash \{1\}$表示一个随机的群元素（$\log_g h$未知）。

分享者持有秘密$s \in Z_p$，构造两个随机多项式

$$a(x) = u_0 + u_1 x + \cdots + u_{t-1} x^{t-1} \bmod p$$

$$b(x) = v_0 + v_1 x + \ldots + v_{t-1} x^{t-1} \bmod p$$

其中$u_0 = s$是秘密，$v_0 \leftarrow_R Z_p$，$u_j, v_j \leftarrow_R Z_p$，$(0 \leqslant j \leqslant t-1)$

4.4 可验证的秘密共享

□ 分享协议：

分发者将份额$s_i = (a(i), b(i))$发送给参与者P_i，并广播$C_j = g^{u_j} h^{v_j} (0 \le j \le t-1)$

收到份额$s_i = (a(i), b(i))$后，参与者P_i通过验证以下等式来确认份额的正确性

$$g^{a(i)} h^{b(i)} = \prod_{j=0}^{t-1} C_j^{i^j} \quad (2)$$

□ 重构协议：

t个参与者分别将各自的秘密份额发送给重构者R，R首先使用等式（2）验证每个参与者的份额是否正确，接下来按照Shamir(t,n)门限秘密共享方案，从t个有效份额中恢复秘密s=a(0)

小结

- 身份认证
- 密钥分配和协商
- 门限密码

哈爾濱工業大學(深圳)
HARBIN INSTITUTE OF TECHNOLOGY, SHENZHEN



谢 谢